Threat Modeling Report

Created on 19/05/2026 12:09:50

Threat Model Name:

Owner:

Reviewer:

Contributors:

Description:

Assumptions:

External Dependencies:

Threat Model Summary:

Not Started	0
Not Applicable	0
Needs Investigation	0
Mitigation Implemented	6
Total	6

Diagram: Diagram 1

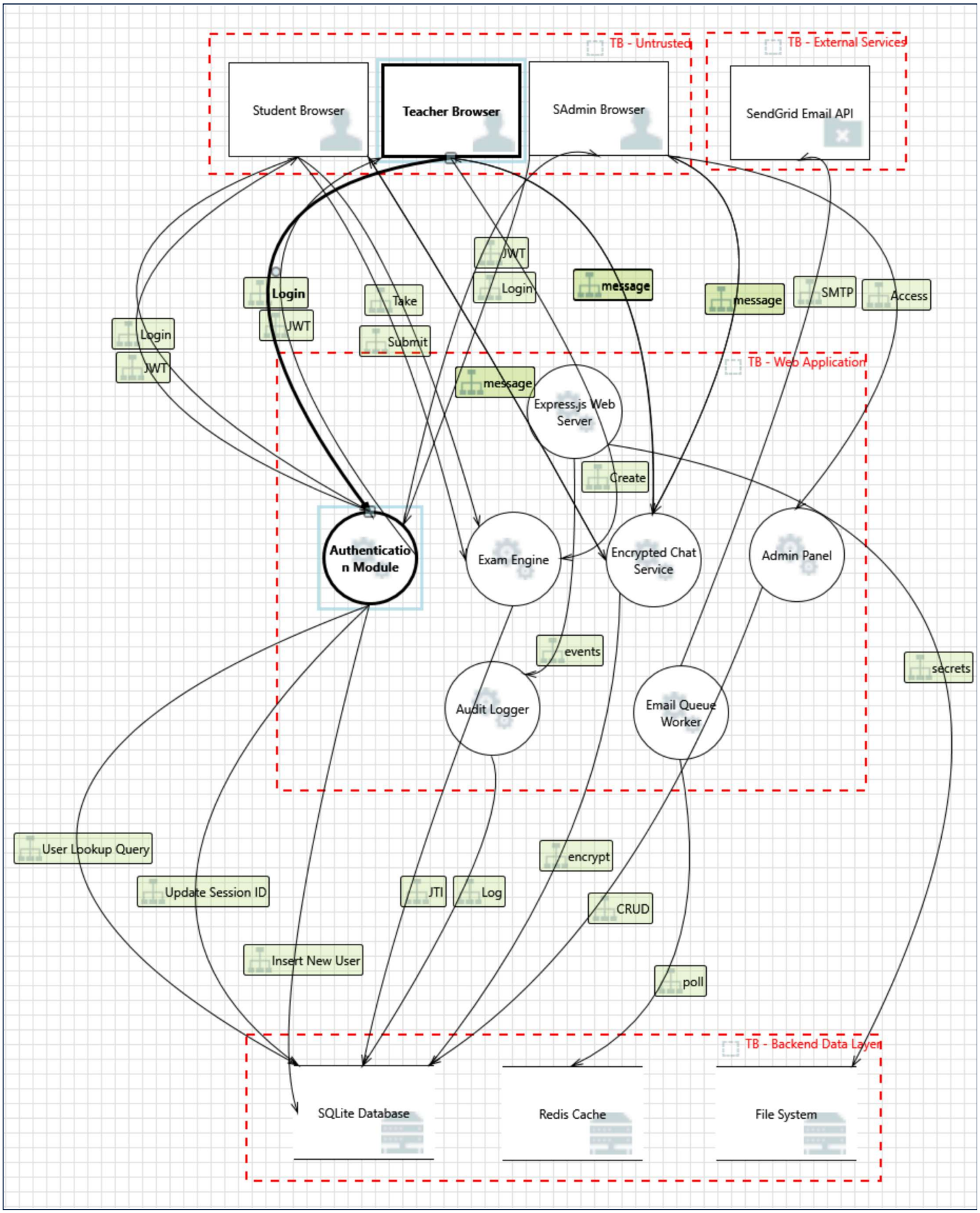
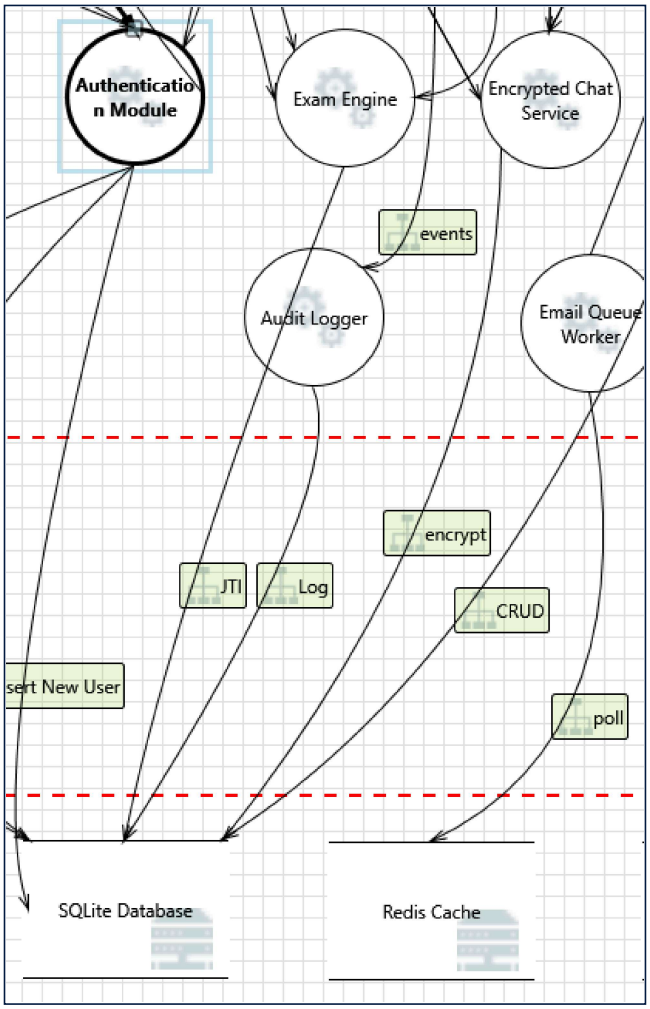


Diagram 1 Diagram Summary:

Not Started	0
Not Applicable	0
Needs Investigation	0
Mitigation Implemented	6
Total	6

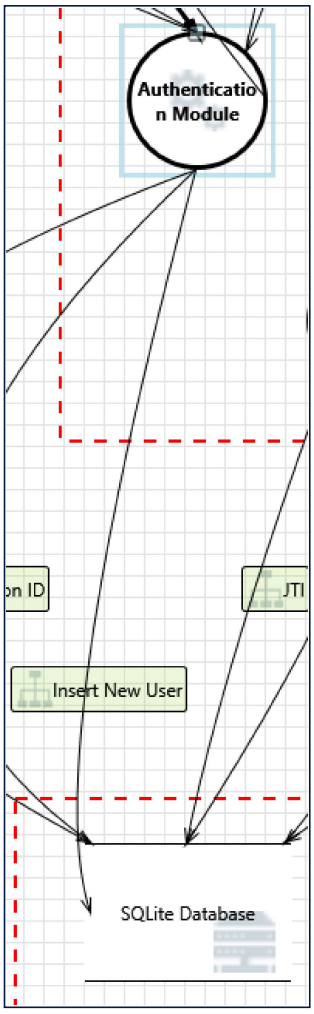
Interaction: encrypt



1. Data Flow Sniffing [State: Mitigation Implemented] [Priority: High]

Category:	Information Disclosure
Description:	Data flowing across encrypt may be sniffed by an attacker. Depending on what type of data an attacker can read, it may be used to attack other parts of the system or simply be a disclosure of information leading to compliance violations. Consider encrypting the data flow.
Justification:	Mitigated by enforcing HTTPS in production with HSTS headers (Strict-Transport-Security: max-age=31536000), which encrypts all data in transit between browser and server. Sensitive data at rest (chat messages) is additionally encrypted with AES-256-CBC with unique IVs, and passwords are hashed with PBKDF2-SHA512 (100,000 iterations).
Short Description:	Information disclosure happens when the information can be read by an unauthorized party.

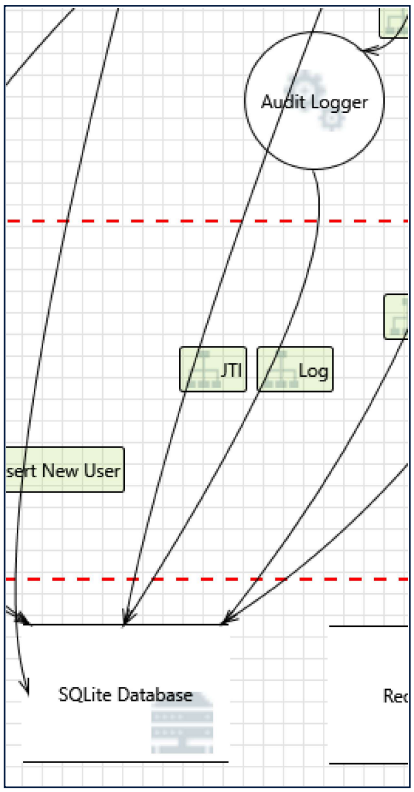
Interaction: Insert New User



2. The SQLite Database Data Store Could Be Corrupted [State: Mitigation Implemented] [Priority: High]

Category:	Tampering
Description:	Data flowing across Insert New User may be tampered with by an attacker. This may lead to corruption of SQLite Database. Ensure the integrity of the data flow to the data store.
Justification:	Mitigated by using better-sqlite3 parameterized prepared statements for all database queries, which prevents SQL injection that could corrupt data. Additionally, input validation middleware (validateRegistration) enforces password policy, format checks, and sanitization before any data reaches the database.
Short Description:	Tampering is the act of altering the bits. Tampering with a process involves changing bits in the running process. Similarly, Tampering with a data flow involves changing bits on the wire or between two running processes.

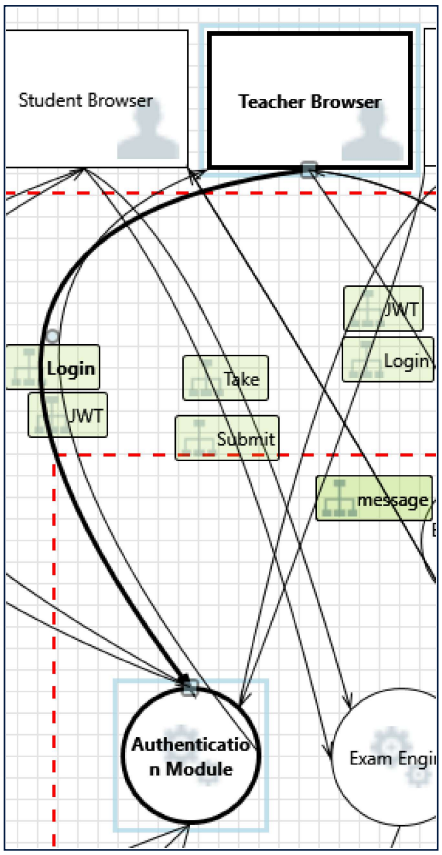
Interaction: Log



3. Data Store Denies SQLite Database Potentially Writing Data [State: Mitigation Implemented] [Priority: High]

Category:	Repudiation
Description:	SQLite Database claims that it did not write data received from an entity on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification:	Mitigated by the append-only audit_logs table that records every write operation (user creation, role changes, exam submissions) with user_id, ip_address, user_agent, and timestamp. Database triggers physically block UPDATE and DELETE on the audit table, making the log tamper-proof and undeniable.
Short Description:	Repudiation threats involve an adversary denying that something happened.

Interaction: Login



4. Spoofing the Authentication Module Process [State: Mitigation Implemented] [Priority: High]

Category:	Spoofing
Description:	Authentication Module may be spoofed by an attacker and this may lead to information disclosure by Teacher Browser. Consider using a standard authentication mechanism to identify the destination process.
Justification:	Mitigated by using JWT tokens signed with HS256 (HMAC-SHA256) using a server-side secret (JWT_SECRET), combined with CAPTCHA verification and 2FA device code validation, ensuring only the legitimate server can issue and verify authentication tokens. Single-session enforcement via current_session_id in the database prevents session spoofing across devices.
Short Description:	Spoofing is when a process or entity is something other than its claimed identity. Examples include substituting a process, a file, website or a network address.

5. Data Flow Generic Data Flow Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category:	Denial Of Service
Description:	An external agent interrupts data flowing across a trust boundary in either direction.
Justification:	Mitigated by express-rate-limit which throttles excessive requests (100/min general, 50/min login, 10/min exam submissions), preventing attackers from flooding the server and interrupting legitimate data flows. Body parser limits (1MB) and account lockout (5 failed attempts → 15 min lock) provide additional DoS resistance.
Short Description:	Denial of Service happens when the process or a datastore is not able to service incoming requests or perform up to spec.

6. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category:	Elevation Of Privilege
Description:	Authentication Module may be able to impersonate the context of Teacher Browser in order to gain additional privilege.
Justification:	Mitigated by strict RBAC middleware (authorize()) that checks the user's role from the database on every request — not from client input — so even if the Auth Module processes a teacher's request, it cannot escalate privileges beyond what the role allows. ABAC middleware (checkOwnership, checkExamAccess) adds attribute-level checks ensuring teachers can only manage their own exams and students can only access enrolled resources.
Short Description:	A user subject gains increased capability or privilege by taking advantage of an implementation bug.